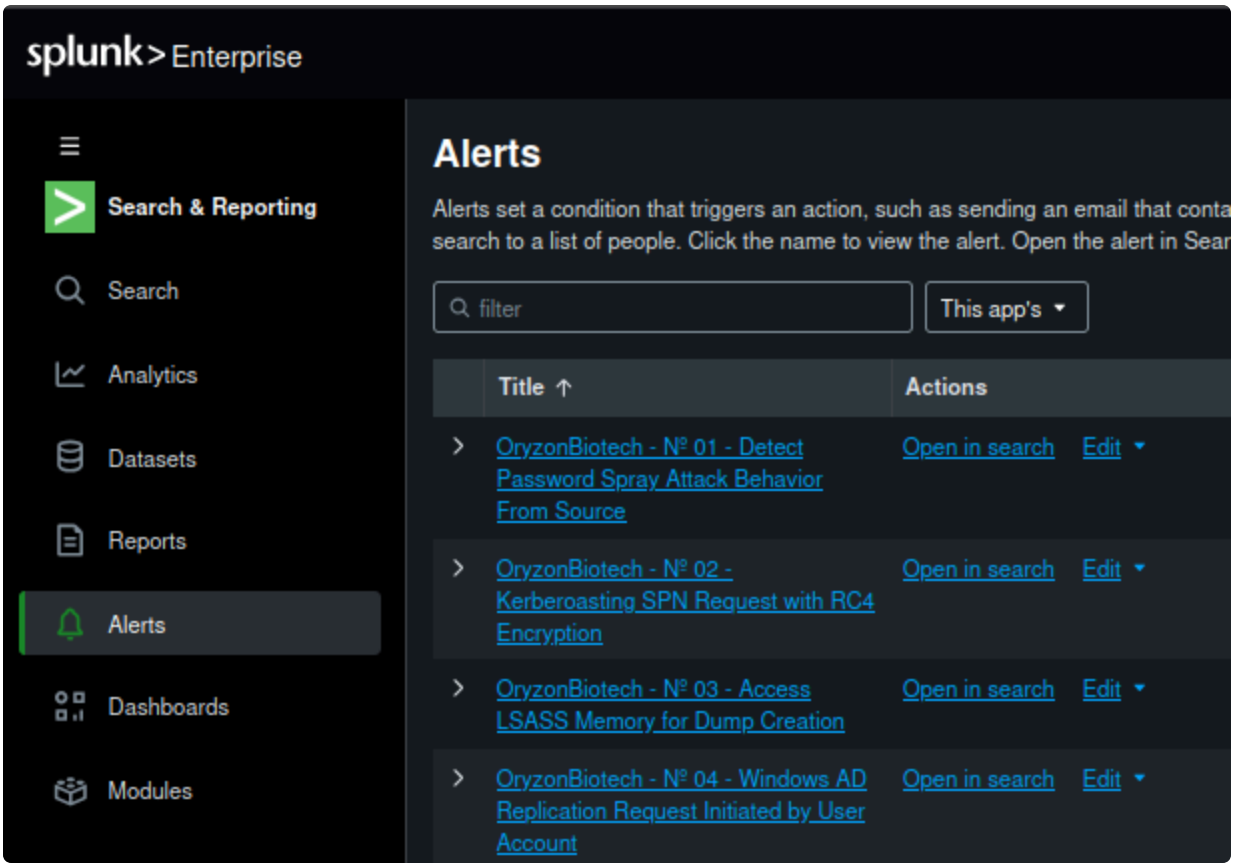
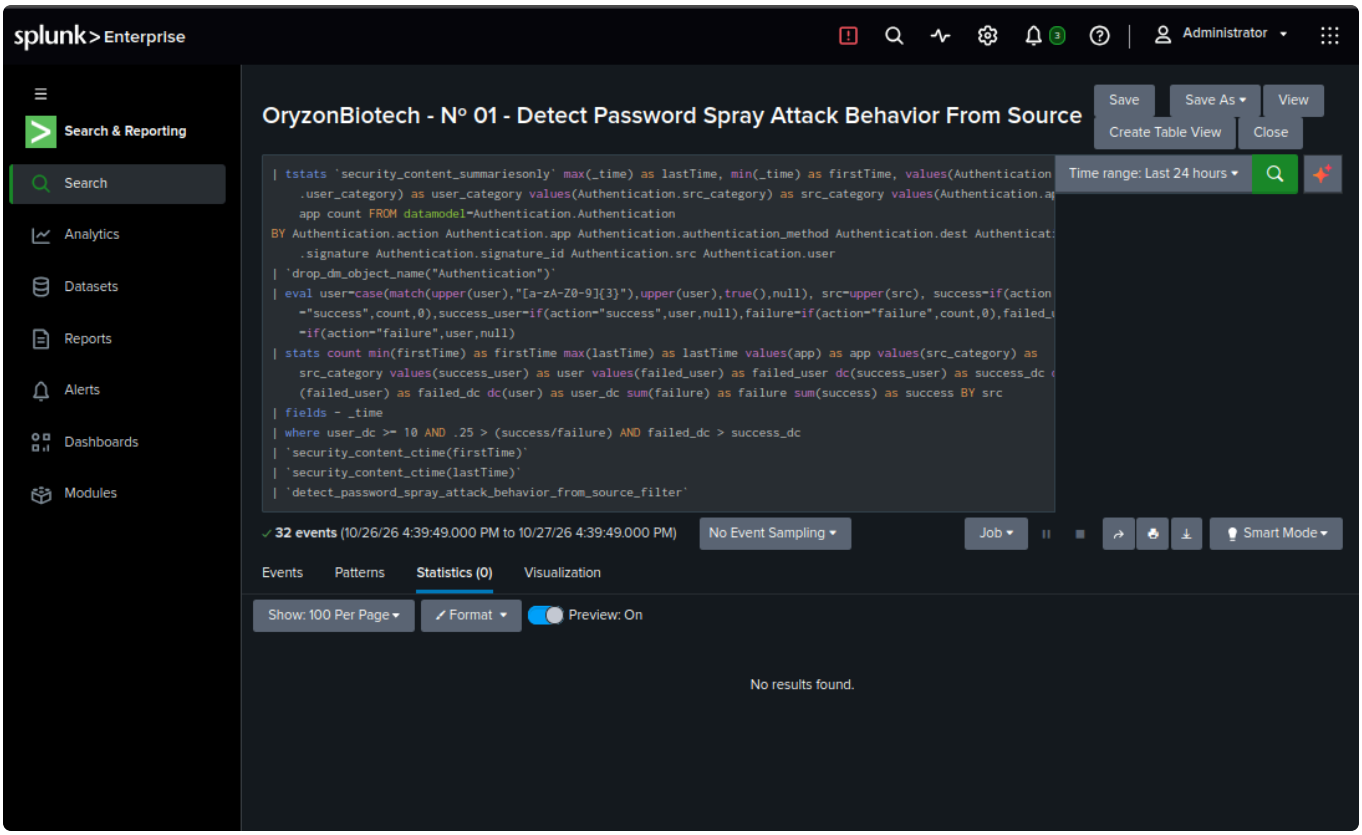
8.Optimización de consultas SPL para las reglas de detección

En este apartado reviso las reglas de detección comunitarias de Splunk seleccionadas previamente y adapto sus consultas SPL a las necesidades y fuentes de datos disponibles en Oryzon Biotech. Explico las modificaciones que implemento antes de iniciar la validación, con el objetivo de dejar las consultas definidas y ajustadas al entorno de la empresa, ampliar la cobertura de las detecciones y facilitar su posterior comprobación. (Probaré y validaré cada regla en el siguiente apartado del proyecto)

Para modificar las alertas creadas en Splunk, accedo a **Alerts**, selecciono la alerta que quiero modificar y, en el menú **Actions**, hago clic en **Open in search**. Desde allí puedo consultar y modificar su búsqueda SPL.





Incluyo únicamente las reglas de detección que modifico o desarrollo. Las que no aparecen en este apartado mantienen sus consultas originales, obtenidas de Splunk Research, sin modificaciones. Reglas de detección que he mejorado:

7.Windows Password Managers Discovery

```
| tstats `security_content_summariesonly` count min(_time) as firstTime
max(_time) as lastTime FROM datamodel=Endpoint.Processes
  WHERE Processes.process = "*dir *"
    OR
    Processes.process = "*findstr*"
    AND
    Processes.process IN (
        "*.kdbx*",
        "*credential*",
        "*key3.db*",
        "*pass*",
        "*cred*",
        "*key4.db*",
        "*accessTokens*",
        "*access_tokens*",
        "*.htpasswd*",
        "*Ntds.dit*",
        "*Login Data*",
        "*logins.json*",
```

```
        "*Local State*",
        "*KeePass*",
        "*passwords*",
        "*credentials*",
        "*Cookies*",
        "*Web Data*",
        "*Credentials*",
        "*vault*",
        "*login data*",
        "*password*.txt*",
        "*pass*.txt*"
    )
  BY Processes.action Processes.dest Processes.original_file_name
     Processes.parent_process Processes.parent_process_exec
Processes.parent_process_guid
     Processes.parent_process_id Processes.parent_process_name
Processes.parent_process_path
     Processes.process Processes.process_exec Processes.process_guid
     Processes.process_hash Processes.process_id
Processes.process_integrity_level
     Processes.process_name Processes.process_path Processes.user
     Processes.user_id Processes.vendor_product
| `drop_dm_object_name(Processes)`
| `security_content_ctime(firstTime)`
| `security_content_ctime(lastTime)`
| `windows_password_managers_discovery_filter`
```

Esta regla detecta intentos de localizar gestores de contraseñas y credenciales. Amplío los patrones de búsqueda para incluir archivos como `Login Data`, `logins.json` y `KeePass`, aumentando la cobertura frente a distintas aplicaciones y formatos de almacenamiento.

8.Windows Credentials in Registry Reg Query

```
| tstats `security_content_summariesonly` count min(_time) as firstTime
max(_time) as lastTime from datamodel=Endpoint.Processes where `process_reg`
AND Processes.process = "* query *" AND Processes.process IN
("*\\Software\\ORL\\WinVNC3\\Password*", "*\\SOFTWARE\\RealVNC\\WinVNC4 /v
password*", "*\\CurrentControlSet\\Services\\SNMP*",
"*\\Software\\TightVNC\\Server*",
"*\\Software\\SimonTatham\\PuTTY\\Sessions*",
"*\\Software\\OpenSSH\\Agent\\Keys*", "*password*",
"*\\Software\\SimonTatham\\PuTTY\\*", "*\\Software\\OpenSSH\\*", "*WinSCP*",
"*\\WinSCP 2\\Sessions*") by Processes.action Processes.dest
Processes.original_file_name Processes.parent_process
Processes.parent_process_exec Processes.parent_process_guid
```

```
Processes.parent_process_id Processes.parent_process_name
Processes.parent_process_path Processes.process Processes.process_exec
Processes.process_guid Processes.process_hash Processes.process_id
Processes.process_integrity_level Processes.process_name
Processes.process_path Processes.user Processes.user_id
Processes.vendor_product
| `drop_dm_object_name(Processes)`
| `security_content_ctime(firstTime)`
| `security_content_ctime(lastTime)`
| `windows_credentials_in_registry_reg_query_filter`
```

Esta regla busca posibles credenciales almacenadas en el Registro de Windows. Incorporo patrones relacionados con PuTTY, OpenSSH y WinSCP para ampliar la detección a más herramientas de conexión remota utilizadas en los equipos de la empresa.

10.Windows Create Local Account

```
index=*
source="WinEventLog:Security" EventCode=4720
| stats count min(_time) as firstTime max(_time) as lastTime
    values(EventCode) as result_id
    by host
| `security_content_ctime(firstTime)`
| `security_content_ctime(lastTime)`
```

Esta regla detecta la creación de cuentas de usuario en Windows mediante el evento de seguridad `4720`. Desarrollo una consulta propia que identifica los equipos afectados y registra la primera y última aparición del evento, adaptándola a las fuentes de datos de la empresa.

15.Windows Scheduled Task with Suspicious Name

```
index=index_agentes_windows host="WindowsSplunkAg" EventCode IN
(4698,4700,4702)
| rex field=Message "Nombre de la tarea:\s+(?<TaskName>[^\r\n]+)"
| rex field=Message "(?s)Contenido de la tarea:\s+(?<TaskContent><\?xml.*?
</Task>)"
| eval TaskName=trim(TaskName)
| eval task_basename=lower(replace(TaskName,"^.*\\\\",""))
| lookup local=t windows_suspicious_tasks task_name as TaskName OUTPUT
tool_type as lookup_tool_type
| eval match_extra=if(task_basename IN (
"windowshealthsync","windowshealthmonitor","windowshealthcache","windowshealth
broker","windowshealthworker","windowshealthagent","windowshealthhelper","wind
owshealthservice","windowshealthreport","windowshealthupdate",
```

```
"systemtelemetrysync","systemtelemetrycache","systemtelemetryworker","systemte
lemetrybroker","systemtelemetryagent","systemtelemetryreport","systemtelemetry
update","systemtelemetrycheck","systemtelemetryhost","systemtelemetrymaint",
"diagnosticdatasync","diagnosticdatacache","diagnosticdataworker","diagnosticd
atabroker","diagnosticdataagent","diagnosticdatareport","diagnosticdataupdate"
,"diagnosticdatacheck","diagnosticdatahost","diagnosticdatamaint",
"securityhealthsync","securityhealthcache","securityhealthworker","securityhea
lthbroker","securityhealthagent","securityhealthreport","securityhealthupdate"
,"securityhealthcheck","securityhealthhost","securityhealthmaint",
"networkhealthsync","networkhealthcache","networkhealthworker","networkhealthb
roker","networkhealthagent","networkhealthreport","networkhealthupdate","netwo
rkhealthcheck","networkhealthhost","networkhealthmaint",
"compatibilitysync","compatibilitycache","compatibilityworker","compatibilityb
roker","compatibilityagent","compatibilityreport","compatibilityupdate","compa
tibilitycheck","compatibilityhost","compatibilitymaint",
"inventorydatasync","inventorydatacache","inventorydataworker","inventorydatab
roker","inventorydataagent","inventorydatareport","inventorydataupdate","inven
torydatacheck","inventorydatahost","inventorydatamaint",
"updatestatussync","updatestatuscache","updatestatusworker","updatestatusbroke
r","updatestatusagent","updatestatusreport","updatestatuscheck","updatestatush
ost","updatestatusmaint","updatestatusservice",
"backgroundhealthsync","backgroundhealthcache","backgroundhealthworker","backg
roundhealthbroker","backgroundhealthagent","backgroundhealthreport","backgroun
dhealthupdate","backgroundhealthcheck","backgroundhealthhost","backgroundhealt
hmaint",
"remotesupportsync","remotesupportcache","remotesupportworker","remotesupportb
roker","remotesupportagent","remotesupportreport","remotesupportupdate","remot
esupportcheck","remotesupporthost","remotesupportmaint",
"sessionhealthsync","sessionhealthcache","sessionhealthworker","sessionhealthb
roker","sessionhealthagent","sessionhealthreport","sessionhealthupdate","sessi
onhealthcheck","sessionhealthhost","sessionhealthmaint",
"browserhealthsync","browserhealthcache","browserhealthworker","browserhealthb
roker","browserhealthagent","browserhealthreport","browserhealthupdate","brows
erhealthcheck","browserhealthhost","browserhealthmaint",
"credentialhealthsync","credentialhealthcache","credentialhealthworker","crede
ntialhealthbroker","credentialhealthagent","credentialhealthreport","credentia
lhealthupdate","credentialhealthcheck","credentialhealthhost","credentialhealt
hmaint",
"policyhealthsync","policyhealthcache","policyhealthworker","policyhealthbroke
r","policyhealthagent","policyhealthreport","policyhealthupdate","policyhealth
check","policyhealthhost","policyhealthmaint",
"storagehealthsync","storagehealthcache","storagehealthworker","storagehealthb
roker","storagehealthagent","storagehealthreport","storagehealthupdate","stora
gehealthcheck","storagehealthhost","storagehealthmaint",
"backuphealthsync","backuphealthcache","backuphealthworker","backuphealthbroke
r","backuphealthagent","backuphealthreport","backuphealthupdate","backuphealth
```

```
check","backuphealthhost","backuphealthmaint",
"deploymenthealthsync","deploymenthealthcache","deploymenthealthworker","deplo
ymenthealthbroker","deploymenthealthagent","deploymenthealthreport","deploymen
thealthupdate","deploymenthealthcheck","deploymenthealthhost","deploymenthealt
hmaint",
"runtimehealthsync","runtimehealthcache","runtimehealthworker","runtimehealthb
roker","runtimehealthagent","runtimehealthreport","runtimehealthupdate","runti
mehealthcheck","runtimehealthhost","runtimehealthmaint",
"taskstatussync","taskstatuscache","taskstatusworker","taskstatusbroker","task
statusagent","taskstatusreport","taskstatusupdate","taskstatuscheck","taskstat
ushost"
),1,0)
| eval tool_type=if(isnotnull(lookup_tool_type) AND
lookup_tool_type!="",lookup_tool_type,if(match_extra=1,"custom_candidate",null
()))
| where isnotnull(tool_type)
| xmlkv TaskContent
| eval Computer=coalesce(Computer,host)
| table _time EventCode Computer TaskName task_basename tool_type Command
Arguments Author Caller_User_Name
```

Esta regla identifica tareas programadas con nombres sospechosos que podrían utilizarse para mantener el acceso a un equipo. Adapto la consulta a los registros en español e incorporo nombres sospechosos adicionales, seleccionando los campos relevantes para facilitar la investigación.

16.Windows Boot or Logon Autostart Execution in Startup Folder

```
| tstats `security_content_summariesonly` count min(_time) as firstTime
max(_time) as lastTime from datamodel=Endpoint.Filesystem where
Filesystem.file_path = "*\\Microsoft\\Windows\\Start
Menu\\Programs\\Startup\\*" OR Filesystem.file_path =
"*\\AppData\\Roaming\\Microsoft\\Windows\\Start Menu\\Programs\\Startup\\*" OR
Filesystem.file_path = "*\\Users\\Public\\Start Menu\\Programs\\Startup\\*" by
Filesystem.action Filesystem.dest Filesystem.file_access_time
Filesystem.file_create_time Filesystem.file_hash Filesystem.file_modify_time
Filesystem.file_name Filesystem.file_path Filesystem.file_acl
Filesystem.file_size Filesystem.process_guid Filesystem.process_id
Filesystem.user Filesystem.vendor_product
| `drop_dm_object_name(Filesystem)`
| `security_content_ctime(firstTime)`
| `security_content_ctime(lastTime)`
| `windows_boot_or_logon_autostart_execution_in_startup_folder_filter`
```

Esta regla detecta archivos que pueden ejecutarse automáticamente al iniciar Windows. Amplío la búsqueda original para incluir las carpetas de inicio de los usuarios y del perfil público, aumentando la cobertura frente a posibles mecanismos de persistencia.

20.Windows Office Product Spawned Uncommon Process

```
| tstats `security_content_summariesonly` count min(_time) as firstTime
max(_time)
as lastTime from datamodel=Endpoint.Processes where
`process_office_products_parent`
AND
(
  Processes.process_name IN (
    bitsadmin.exe,
    certutil.exe,
    cmd.exe,
    cscript.exe,
    forfiles.exe,
    hh.exe,
    mshta.exe,
    powershell.exe,
    pwsh.exe,
    regsvr32.exe,
    rundll32.exe,
    wmic.exe,
    wscript.exe
  )
  OR
  Processes.original_file_name IN (
    bitsadmin.exe,
    CertUtil.exe,
    Cmd.Exe,
    cscript.exe,
    forfiles.exe,
    hh.exe,
    MSHTA.EXE,
    PowerShell.EXE,
    pwsh.dll,
    REGSVR32.EXE,
    RUNDLL32.EXE,
    wmic.exe,
    wscript.exe
  )
)
by Processes.action Processes.dest Processes.original_file_name
   Processes.parent_process Processes.parent_process_exec
```

```
Processes.parent_process_guid
   Processes.parent_process_id Processes.parent_process_name
Processes.parent_process_path
   Processes.process Processes.process_exec Processes.process_guid
Processes.process_hash
   Processes.process_id Processes.process_integrity_level
Processes.process_name Processes.process_path
   Processes.user Processes.user_id Processes.vendor_product
| `drop_dm_object_name(Processes)`
| `security_content_ctime(firstTime)`
| `security_content_ctime(lastTime)`
| `windows_office_product_spawned_uncommon_process_filter`
```

Esta regla detecta procesos poco habituales iniciados por aplicaciones de Office. Añado `forfiles.exe` y `hh.exe` a los criterios originales para ampliar la detección de posibles ejecuciones sospechosas, aunque esto puede generar falsos positivos.

21.Ransomware Notes bulk creation

```
index=* source="*Sysmon*" EventCode=11
| eval file_name=replace(TargetFilename, "^.*\\\\", "")
| where match(TargetFilename, "(?i)\\.
(txt|html|htm|hta|rtf|md|xml|pdf|jpg|png|url|log|readme|locked|decrypt|recover
|restore|pay|encrypted)$")
| bin _time span=10s
| stats min(_time) as firstTime
    max(_time) as lastTime
    dc(TargetFilename) as unique_readme_path_count
    values(TargetFilename) as list_of_readme_path
    values(action) as action
    values(file_access_time) as file_access_time
    values(file_hash) as file_hash
    values(file_modify_time) as file_modify_time
    values(file_path) as file_path
    values(file_acl) as file_acl
    values(file_size) as file_size
    values(process_guid) as process_guid
    values(process_id) as process_id
    values(user) as user
    values(vendor_product) as vendor_product
    values(Image) as Image
    by host file_name _time
| where unique_readme_path_count >= 5
| eval dest=host
```

```
| `security_content_ctime(firstTime)`
| `security_content_ctime(lastTime)`
```

Esta regla detecta la creación masiva de posibles notas de rescate. Amplío los formatos de archivo examinados y reduzco el umbral de 15 a 5 rutas distintas para detectar posibles ataques con menos archivos, asumiendo el riesgo de generar más falsos positivos.

24.Windows Exfiltration Over C2 Via Invoke RestMethod

```
index=* EventCode=4104
| eval ScriptText=coalesce(ScriptBlockText, Message)
| where match(ScriptText, "(?i)\bInvoke-RestMethod\b")
| where match(ScriptText, "(?i)(-Uri\s+|-Method\s+|-Body\s+|-InFile\s+)")
| eval Detection="PowerShell Invoke-RestMethod Activity"
| stats count min(_time) as firstTime max(_time) as lastTime values(host) as
host values(source) as source values(sourcetype) as sourcetype values(user) as
user values(ScriptText) as ScriptText by index Detection
| convert ctime(firstTime) ctime(lastTime)
```

Esta regla detecta el uso potencialmente sospechoso de `Invoke-RestMethod` en PowerShell. Adapto la búsqueda a los registros disponibles, permito analizar distintos campos del evento y flexibilizo los parámetros exigidos para ampliar la detección de posibles intentos de extracción de información, aunque aumenta el riesgo de falsos positivos.